

SIT 218/738: Secure coding

Pass task 1.1P: Apply software security principles to answer the following questions.

Note: Before working on this task, you need to read the content of week-1 in CloudDeakin.

Overview

Your task is to explain what software security principles are being applied or validated in the below scenarios.

1. A mid-sized SaaS company frequently releases new features to stay competitive. However, security measures—such as input validation, strong encryption ciphers, and others—are only added after incidents of exploitation or suspicious activities are reported.
Explain which security principle is being violated and how this can be mitigated. Additionally, discuss how the organization can remain competitive while ensuring their software is secure.
2. An enterprise application relies on an authentication mechanism that uses relational database management systems (RDBMS) to verify user credentials. During an unexpected high-usage situation, the RDBMS fails. The developers used a fallback mechanism which had error and also bypassed credentials checks. As a result, even unauthenticated requests are granted access to the application. Explain briefly which software security principle was violated and describe the process to mitigate it.
3. A mature DevSecOps team at an organisation enforces a policy that prohibits developers approving their own code for release. However, due to staffing constraints, a developer who implemented a major feature occasionally participates in QA testing and also handles product release deadlines. Over time, this becomes routine practice within the team. Explain which secure software development principles are being followed or violated in this situation?
4. A weather forecasting platform allows third-party services to access their forecasting application through a public API. The platform also communicates with other internal microservices and APIs. However, the software provider secures only the public APIs, assuming that the internal microservices and APIs are safe because they operate within a trusted network. Which secure coding principle should developers apply to minimize the security risks associated with unsecured internal services and APIs? Explain briefly.
5. The mitigation strategy for CSRF attacks requires applying security measures at various levels such as input validation, validating session cookies, verifying origin headers. What secure coding principle is being applied in this case? Explain briefly.
6. An “Application A” makes an API call to email handling “Application B” to generate a to-do list from user flagged emails. However, the developer also grants read access to the contact list which is not required by the “Application A”. Which secure coding principle should developers apply to reduce the security risks posed associated with granting unnecessary access rights? Explain briefly.

7. An organization enforces a policy that provides the administrator with only one account:-an administrative account. This account is used to perform both administrative tasks and routine, day-to-day activities by the administrator. Explain which security principle is being violated in this scenario and how this can be mitigated.

Please do your own research and try to collect as much information as possible. When you use information from other sources, remember to cite them, else it will be considered as plagiarism. You CAN NOT direct copy paste even if you provide proper in-text citations and bibliographic references at the end.

Hints:

[Principles of security - OWASP Developer Guide](https://devguide.owasp.org/en/02-foundations/03-security-principles/)

<https://devguide.owasp.org/en/02-foundations/03-security-principles/>

Submission Requirements:

Submit one PDF file via OnTrack and use references appropriately. One-word answers are not acceptable.

Submission Due

The due for each task has been stated via its OnTrack task information dashboard.